

SEMINÁRIO

Autenticação & Autorização

Como os sistemas descobrem quem é o usuário e decidem o que ele pode fazer.

Lorenzo dos Reis

Parte 1 — Autenticação

Arthur Novak

Parte 2 — Autorização

Andrei Cecatto

Parte 3 — Segurança na prática



O que vamos ver

01

Autenticação

Fatores, MFA e métodos modernos de provar identidade.

APRESENTADOR 1

02

Autorização

RBAC, ABAC e ACL, OAuth 2.0, OpenID Connect e JWT.

APRESENTADOR 2

03

Segurança na prática

Falhas do OWASP, checklist de boas práticas e tendências.

APRESENTADOR 3

01

Autenticação

Quem é você? Como um sistema verifica a identidade de quem está do outro lado.

- Lorenzo dos Reis

O que é autenticação

É o processo de **comprovar que uma identidade declarada é verdadeira**, antes de o sistema conceder qualquer acesso.

Declarar quem se é (o login) não basta: é a prova apresentada — senha, código, biometria — que autentica o usuário.

- 1 Identificação**
O usuário informa quem diz ser
- 2 Verificação**
O sistema confere a prova apresentada
- 3 Sessão**
A identidade passa a valer por tempo limitado

Fatores de autenticação

Toda prova de identidade cai em uma destas três categorias.

CONHECIMENTO

Algo que você sabe

Senha, PIN, resposta secreta.

Pode ser descoberto, reutilizado ou vazado.

POSSE

Algo que você tem

Celular com app autenticador, chave FIDO, cartão.

Exige acesso físico ao dispositivo.

INERÊNCIA

Algo que você é

Impressão digital, face, voz.

Não se troca depois de comprometido.

Autenticação multifator

MFA é combinar fatores de **categorias diferentes**.
Duas senhas não são dois fatores.

O atacante que descobre a senha ainda precisa do dispositivo do usuário — e é isso que derruba ataques em massa de credenciais vazadas.

FORTE

Senha + chave FIDO ou passkey

Resistente a phishing por vínculo ao domínio

BOM

Senha + código TOTP do app

Código local, válido por 30 segundos

FRÁGIL

Senha + código por SMS

Vulnerável a SIM swap e interceptação

Métodos em uso hoje

Senha com hash

Armazenada como hash lento e com salt — bcrypt, scrypt ou Argon2, nunca em texto puro.

`argon2id$v=19$m=65536`

TOTP

Código de 6 dígitos gerado do segredo compartilhado mais o horário atual.

`HMAC(segredo, tempo/30)`

Biometria

A comparação acontece no dispositivo; o servidor recebe só o resultado, não a digital.

`match local → assinatura`

Passkeys (WebAuthn)

Par de chaves por site: a privada fica no dispositivo, o servidor guarda só a pública.

`desafio → assinatura → OK`

Por dentro do login

O que acontece entre clicar em “Entrar” e ver a tela inicial.

01 · BUSCA

Localizar a conta

O servidor procura o usuário e recupera o hash guardado — nunca uma senha.

02 · RECÁLCULO

Aplicar o mesmo hash

A senha digitada passa pela mesma função, com o salt que está salvo junto ao registro.

03 · COMPARAÇÃO

Comparar hashes

Se os dois resultados são iguais, a senha estava certa. O servidor segue sem saber qual ela é.

04 · SESSÃO

Emitir a credencial

Só então nasce o token ou cookie de sessão, com prazo de validade definido.

```
guardado: argon2id$v=19$m=65536$salt$hash
```

```
digitado: "senha-do-usuario"
```

```
verify(digitado, guardado) → true
```

POR QUE O HASH É LENTO

Meio segundo por tentativa é imperceptível no login, mas transforma bilhões de chutes em anos de trabalho para o atacante.

Cada método tem seu ataque

Não existe método perfeito — existe método adequado à ameaça que você enfrenta.

MÉTODO	Como cai	O que segura
Senha	Vazamento em outro site, reuso e chute automatizado	Hash lento com salt, limite de tentativas, senha longa
Código por SMS	Troca de chip na operadora e interceptação da mensagem	Trocar por app autenticador — SMS só como último recurso
TOTP no app	Site falso que pede o código e o usa no mesmo instante	Janela curta, um uso por código e alerta de acesso novo
Biometria	Falsificação do sensor — e o dado não pode ser trocado depois	Comparação dentro do aparelho; usar como desbloqueio, não como senha
Passkey	Perda do dispositivo e recuperação de conta mal feita	Chave presa ao domínio: site clonado não consegue usá-la

02

Autorização

O que você pode fazer? Modelos de permissão, delegação de acesso e tokens.

- Arthur Novak

Autenticação não é autorização

CRITÉRIO	Autenticação	Autorização
Pergunta	Quem é você?	O que você pode fazer?
Quando ocorre	Uma vez, na entrada	A cada requisição
Evidência	Senha, código, biometria	Papéis, atributos, políticas
Falha responde	401 Unauthorized	403 Forbidden

Modelos de controle de acesso

RBAC

POR PAPEL

Permissões ficam no papel; o usuário recebe papéis.

`admin → editar tudo leitor → apenas ver`

ABAC

POR ATRIBUTO

Regras avaliam atributos do usuário, do recurso e do contexto.

`setor = financeiro e horário comercial`

ACL

POR RECURSO

Cada recurso carrega a lista de quem pode o quê.

`doc-42: ana=rw doc-42: joão=r`

MESMA PERGUNTA, TRÊS RESPOSTAS

“O professor pode lançar esta nota?”

RBAC

Pergunta ao **papel** do usuário. A permissão está no cargo, não na pessoa.

```
papel: professor
permissões: lancar_nota,
ver_turma
papel tem lancar_nota → ok
```

Ganha: simples de auditar

Perde: não sabe de qual turma

ABAC

Pergunta aos **atributos** de usuário, recurso e contexto, avaliados por uma regra.

```
permitir se
user.id = turma.professorId
e semestre = "ativo"
regra verdadeira → ok
```

Ganha: expressa “só a minha turma”

Perde: difícil saber quem pode o quê

ACL

Pergunta ao **recurso** : cada item guarda a própria lista de quem pode o quê.

```
turma calc-III:
nogueira = escrever
coordenacao = ler
consta na lista → ok
```

Ganha: controle item a item

Perde: muitas listas para manter

NA VIDA REAL

Os três convivem: RBAC define o cargo, ABAC refina com contexto e ACL trata o compartilhamento pontual.

OAUTH 2.0 um protocolo de delegação, não de login

O problema que o OAuth resolve

Um app de agenda precisa ler seu calendário. Como dar esse acesso sem entregar sua senha?

ANTES

Entregar a senha

O app guarda sua senha e entra como se fosse você

Acesso total: agenda, e-mail, arquivos, tudo

Só dá para revogar trocando a senha

COM OAUTH 2.0

Entregar um token limitado

A senha nunca sai do provedor de identidade

O token vale só para o escopo aprovado

Pode ser revogado sem afetar a conta

ESCOPO `scope=calendar.read` o app lê a agenda e nada mais — nem apaga evento, nem vê e-mail

Quem é quem no OAuth 2.0

Quatro papéis, sempre os mesmos — muda apenas quem ocupa cada um.

RESOURCE OWNER

Dono do dado

Quem aprova ou recusa o acesso.

você, o usuário

CLIENT

Aplicação

Quem pede o acesso e usa o token.

o app de agenda

AUTH SERVER

Provedor de identidade

Autentica o usuário e emite os tokens.

a conta institucional

RESOURCE SERVER

API protegida

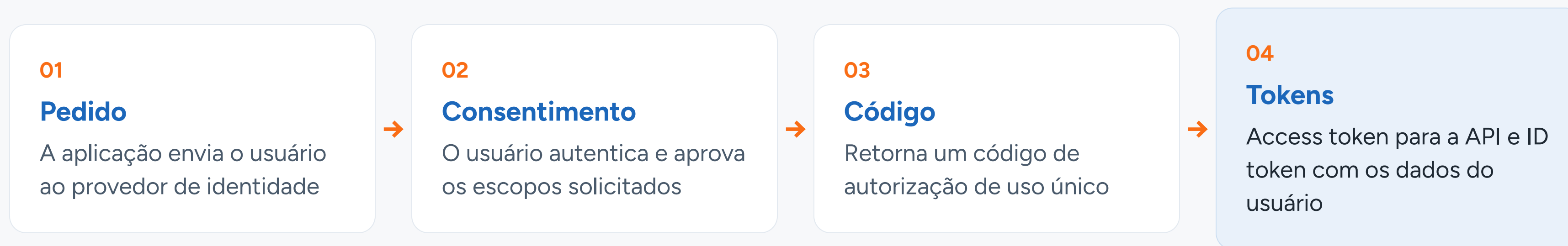
Confere o token e devolve o dado.

a API do calendário

NA PRÁTICA O app nunca vê a senha: ele recebe do provedor um token que a API aceita.

Fluxo OAuth 2.0 e OpenID Connect

OAuth 2.0 delega acesso; o OpenID Connect acrescenta a camada de identidade.



ACCESS TOKEN

autoriza chamadas à API

ID TOKEN

informa quem é o usuário autenticado

OPENID CONNECT

a camada de identidade sobre o OAuth 2.0

“Entrar com a sua conta”

O OAuth diz o que o app pode fazer. O OIDC acrescenta quem é o usuário.

ACCESS TOKEN · OAUTH

Um cartão de acesso

Vai junto na chamada à API. O app não precisa entender seu conteúdo — quem valida é o servidor de recursos.

```
Authorization: Bearer ey...
scope=calendar.read
```

ID TOKEN · OIDC

Uma carteira de identidade

JWT assinado, feito para o app ler: diz quem entrou, quando e por qual provedor.

```
sub: "1045"
email, name, iat, exp
```

ERRO COMUM

Usar o access token para identificar o usuário. Ele autoriza uma chamada, não prova identidade — para isso existe o ID token, com scope=openid.

Anatomia de um JWT

```
eyJhbGciOiJIUzI1NiJ9.eyJzdWIiOiIxMDIiLCJyb2x1IjoieYWRtaW4ifQ.Kx7f2Qa9nR1sYb0cLmT4wZp
```

Header

Algoritmo e tipo do token.

`alg, typ, kid`

Payload

Claims: quem é, o que pode, até quando vale.

`sub, role, exp, iss`

Signature

Garante integridade — só o emissor consegue produzi-la.

HS256 ou RS256

O payload é apenas codificado em Base64, não criptografado: qualquer um pode ler o conteúdo.

03

Segurança na prática

Onde esses controles falham no mundo real e o que já é padrão para evitar isso.

- Andrei Cecatto

OWASP A01 a falha mais frequente em aplicações web

Quebra de controle de acesso

O usuário está autenticado, mas consegue fazer mais do que deveria.

IDOR

Trocar o ID na URL

O sistema entrega o registro pedido sem checar se ele pertence a quem pediu.

```
/perfil?id=1045 ✓ meu  
/perfil?id=1046 ✓ de outro
```

CLIENTE VS SERVIDOR

Permissão só na interface

O botão está escondido na tela, mas a API aceita a chamada de qualquer usuário.

```
botão oculto na tela  
DELETE /api/notas/88 → 200
```

ROTA ABERTA

Área administrativa sem checagem

O endereço não aparece no menu, mas responde para quem digita direto.

```
papel: aluno  
GET /admin → 200
```

OWASP A07 falhas na prova de identidade e na sessão

Falhas de identificação e autenticação

O atacante não burla a permissão: ele entra como se fosse o usuário.

CREDENTIAL STUFFING

Senha vazada reaproveitada

A senha do usuário caiu no vazamento de outro site e é testada aqui em massa.

lista de 2 mi de e-mails
0,3% dos logins funcionam

FORÇA BRUTA

Sem limite de tentativas

O formulário aceita tentativas seguidas, sem espera nem bloqueio temporário.

6 erros em 8 segundos
7ª tentativa → entrou

SESSÃO

Token que nunca expira

Sem prazo nem revogação, quem copia o token continua dentro mesmo após a troca de senha.

login em 2025
cookie válido até 2027

CHECKLIST se só der tempo de três, sejam estas

As três que mais importam

01 · AUTORIZAÇÃO

Negar por padrão, no servidor

Toda rota começa fechada e cada requisição pergunta se este usuário pode acessar este recurso.

```
if (nota.alunoId ≠ sessao.id)
  return 403;
```

02 · AUTENTICAÇÃO

Hash forte e MFA no privilégio

Senha nunca em texto puro; segundo fator obrigatório para quem administra o sistema.

```
argon2id(senha, salt)
papel = admin → exige TOTP
```

03 · SESSÃO

Token curto e revogável

Prazo de minutos, renovação por refresh e invalidação imediata no logout e na troca de senha.

```
access: 15 min
logout → revoga refresh
```

E TAMBÉM

Rate limit e bloqueio progressivo

Erro genérico: "Credenciais inválidas."

Log de acesso negado e troca de permissão

Para onde a área caminha

TENDÊNCIA 01

Zero Trust

Nenhuma rede é confiável por estar dentro do perímetro: identidade, dispositivo e contexto são verificados em cada acesso.

TENDÊNCIA 02

Passwordless

Passkeys e chaves FIDO2 substituem a senha por criptografia de chave pública — sem segredo para vazar ou phishar.

TENDÊNCIA 01 “nunca confie, sempre verifique”

Zero Trust

O modelo antigo tratava a rede interna como zona segura: quem entrava pela VPN alcançava tudo. Um notebook comprometido derrubava o perímetro.

PRINCÍPIO**Verificar sempre**

Cada requisição é avaliada de novo: identidade, dispositivo, localização e horário. Estar na rede da empresa não vale nada.

PRINCÍPIO**Privilégio mínimo**

Acesso ao que a tarefa exige, pelo tempo que ela durar. Permissão elevada vira exceção aprovada, não o padrão da conta.

PRINCÍPIO**Assumir a invasão**

Projetar como se o atacante já estivesse dentro: segmentação, log de tudo e capacidade de revogar sessões na hora.

DECISÃO POR CONTEXTO

usuário ok · dispositivo gerenciado · horário usual

→ acesso liberado

mesmo usuário · dispositivo novo · outro país

→ exige MFA ou nega

NO CÓDIGO DO DIA A DIA

Cada serviço valida o token — não confia no serviço vizinho

Sessão curta com reavaliação, não login eterno

Permissão checada no servidor, sempre, mesmo em rede interna

TENDÊNCIA 02

passkeys e FIDO2 / WebAuthn

Passwordless

Sem segredo compartilhado: o servidor guarda só a chave pública. Não há o que vazar num banco de dados nem o que digitar num site falso.

01 · CADASTRO

O dispositivo cria um par de chaves só para aquele site e envia a pública

**02 · DESAFIO**

No login, o servidor envia um número aleatório para ser assinado

**03 · ASSINATURA**

Biometria libera a chave privada, que nunca sai do aparelho, e assina o desafio

POR QUE RESISTE A PHISHING

A chave está presa ao domínio verdadeiro. Num site clonado o navegador não encontra a passkey — não existe o que enganar o usuário a digitar.

origin: unisystem.edu.br ✓

origin: unisystem-login.co ✗

O QUE AINDA PESA

Recuperação de conta ao perder o dispositivo

Sincronização entre plataformas diferentes

Convivência com a senha durante a transição

Recapitulando o modelo

ETAPA 01

Autenticação

Confirma quem está acessando.



ETAPA 02

Autorização

Define o que essa identidade pode fazer.



ETAPA 03

Auditoria

Registra o que foi feito e por quem.

As três etapas se sustentam juntas: autenticar sem autorizar libera demais, autorizar sem auditar deixa o incidente invisível.

CAÇA ÀS FALHAS

Você é o analista de segurança. O que está errado neste sistema?

Nas próximas telas você percorre o UniSystem exatamente como um usuário o encontra: telas de acesso, perfil, painel administrativo, log do servidor e sessão.

Encontre exatamente 13 de autenticação, autorização e sessão falhas



UniSystem
Sistema Acadêmico · lançamento em 2 semanas

PERFIS DE ACESSO

- Aluno
- Professor
- Administrador

COMO REGISTRAR

Na tabela impressa, escreva em que tela você viu a evidência e o que ela permite a um atacante. Uma linha por achado.

ATOR DO CENÁRIO

João, aluno do 3º semestre, matrícula 1045. Usa os computadores da biblioteca.

UniSystem — Acesso

← → ↺

i

http://unisystem.edu.br/login

UniSystem

Universidade · Portal Acadêmico

Portal Acadêmico

Matrícula, notas, histórico e documentos em um único ambiente.

Disponível nos laboratórios e na biblioteca

Dúvidas: suporte@unisystem.edu.br

Entre com sua conta institucional:

Usuário

joao@universidade.edu.br

Senha

123

Mínimo de 3 caracteres.

☒ Manter-me conectado neste computador

Acessar

Esqueceu sua senha?

Instruções para novos alunos

Ao clicar em Acessar você entra direto no portal — nenhuma outra confirmação é solicitada.

UniSystem · Núcleo de Tecnologia

Contato · Serviços

UniSystem — Acesso

← → ↺

i

http://unisystem.edu.br/login

começa com "http": a senha viaja sem proteção pela rede

UniSystem

Universidade · Portal Acadêmico

Portal Acadêmico

Matrícula, notas, histórico e documentos em um único ambiente.

Disponível nos laboratórios e na biblioteca

Dúvidas: suporte@unisystem.edu.br

▶ A própria tela avisa: com a senha certa entra direto, sem nenhuma outra confirmação. Quem descobrir a senha entra — faltou um segundo passo, como o código do aplicativo no celular.

▶ A opção já vem marcada, sem o usuário pedir: em qualquer computador compartilhado, o próximo a usar entra na conta do João.

Entre com sua conta institucional:

Usuário

joao@universidade.edu.br

Senha

123

Mínimo de 3 caracteres.

▶ Uma senha de 3 dígitos é chutada em segundos. O sistema deveria exigir senhas longas e recusar as mais óbvias.

☒

Manter-me conectado neste computador

Acessar

Esqueceu sua senha?

Instruções para novos alunos

Ao clicar em Acessar você entra direto no portal — nenhuma outra confirmação é solicitada.

UniSystem · Núcleo de Tecnologia

Contato · Serviços

http://unisystem.edu.br/login

UniSystem

TENTATIVA • 09:41

⚠ **Usuário não encontrado.**

Usuário

maria.silva@universidade.edu.br

Senha

.....

Acessar

http://unisystem.edu.br/login

UniSystem

TENTATIVA • 09:42

⚠ **Senha incorreta.**

Usuário

joao@universidade.edu.br

Senha

.....

Você pode tentar novamente imediatamente.

Acessar

http://unisystem.edu.br/login

UniSystem

TENTATIVA • 09:41

!

Usuário não encontrado.

► O sistema avisa que esse e-mail não existe. Comparando as respostas, dá para descobrir quem tem conta.

Usuário

maria.silva@universidade.edu.br

Senha

.....

Acessar

http://unisystem.edu.br/login

UniSystem

TENTATIVA • 09:42

!

Senha incorreta.

► Aqui ele confirma: a conta existe, só a senha está errada. As duas mensagens deveriam ser iguais.

Usuário

joao@universidade.edu.br

Senha

.....

Você pode tentar novamente imediatamente.

► Pode errar quantas vezes quiser. Depois de algumas tentativas o sistema deveria travar o acesso por um tempo.

Acessar

```
●●● tail -f /var/log/unisystem/access.log

09:42:03 10.0.4.21 POST /login 401 user=joao@universidade.edu.br
09:42:05 10.0.4.21 POST /login 401 user=joao@universidade.edu.br
09:42:06 10.0.4.21 POST /login 401 user=joao@universidade.edu.br
09:42:08 10.0.4.21 POST /login 401 user=joao@universidade.edu.br
09:42:09 10.0.4.21 POST /login 401 user=joao@universidade.edu.br
09:42:11 10.0.4.21 POST /login 200 user=joao@universidade.edu.br
Set-Cookie: session=8f2c...ae; Path=/; Expires=Wed, 09 Sep 2027 09:42:11 GMT
09:43:40 10.0.4.21 GET /perfil?id=1045 200
09:44:02 10.0.4.21 GET /perfil?id=1046 200
09:44:55 10.0.4.21 POST /perfil/1045 200 tipo_usuario=administrador
09:45:20 10.0.4.21 GET /admin 200
09:45:21 10.0.4.21 GET /admin/permissoes 200
```

CONFIGURAÇÃO DA APLICAÇÃO

SESSION_LIFETIME = null
PASSWORD_MIN_LEN = 3
LOGIN_THROTTLE = off
FORCE_HTTPS = false
MFA_ENABLED = false

TABELA usuarios

id	email	senha
1045	joao@...	123
1046	ana@...	ana2024
1002	admin@...	admin

```
●●● tail -f /var/log/unisystem/access.log

09:42:03 10.0.4.21 POST /login 401 user=joao@universidade.edu.br
09:42:05 10.0.4.21 POST /login 401 user=joao@universidade.edu.br
09:42:06 10.0.4.21 POST /login 401 user=joao@universidade.edu.br
09:42:08 10.0.4.21 POST /login 401 user=joao@universidade.edu.br
09:42:09 10.0.4.21 POST /login 401 user=joao@universidade.edu.br
09:42:11 10.0.4.21 POST /login 200 user=joao@universidade.edu.br
Set-Cookie: session=8f2c...ae; Path=/; Expires=Wed, 09 Sep 2027 09:42:11 GMT

09:43:40 10.0.4.21 GET /perfil?id=1045 200
09:44:02 10.0.4.21 GET /perfil?id=1046 200
09:44:55 10.0.4.21 POST /perfil/1045 200 tipo_usuario=administrador
09:45:20 10.0.4.21 GET /admin 200
09:45:21 10.0.4.21 GET /admin/permissoes 200
```

► Seis erros de senha em 8 segundos e depois um acerto: alguém testou senhas até entrar.

► O “crachá” entregue no login vale até 2027: quase dois anos conectado.

► O sistema entregou a página de outro aluno sem reclamar.

► O aluno mandou “sou administrador” e o sistema acreditou.

► As páginas de administração abriram normalmente para um aluno.

CONFIGURAÇÃO DA APLICAÇÃO

SESSION_LIFETIME = null
PASSWORD_MIN_LEN = 3
LOGIN_THROTTLE = off
FORCE_HTTPS = false
MFA_ENABLED = false

TABELA usuarios

id	email	senha
1045	joao@...	123
1046	ana@...	ana2024
1002	admin@...	admin

- As senhas estão guardadas como texto, dá para ler todas. O certo é gravar embaralhadas, sem volta.

← → ↺

http://unisystem.edu.br/perfil?id=1045

UniSystem

InícioDisciplinasNotasMeu perfil

João · Aluno

MENU

Dados pessoais

Documentos

Histórico

Matrícula

Sair

✓ Perfil atualizado com sucesso!

Nome completo

João Pereira dos Santos

Matrícula

1045

E-mail

joao@universidade.edu.br

Telefone

(55) 99xxx-4410

Tipo de usuário

Administrador ▼

Curso

Ciência da Computação

Opções: Aluno, Professor, Administrador

Salvar alterações

Cancelar

← → ↺

http://unisystem.edu.br/perfil?id=1045

UniSystem

Início Disciplinas Notas Meu perfil João · Aluno

MENU

Dados pessoais

Documentos

Histórico

Matrícula

Sair

✓ **Perfil atualizado com sucesso!** o próprio aluno acabou de virar administrador

Nome completo

João Pereira dos Santos

Matrícula

1045

E-mail

joao@universidade.edu.br

Telefone

(55) 99xxx-4410

Tipo de usuário

Administrador ▼

Curso

Ciência da Computação

Opções: Aluno, Professor, Administrador

Salvar alterações

Cancelar

▶ O aluno escolheu o próprio cargo no formulário e virou administrador. Quem define cargo é a coordenação, não o usuário.

← → ↺

http://unisystem.edu.br/perfil?id=1046

UniSystem

InícioDisciplinasNotasMeu perfil

João · Aluno

AL

Ana Luiza Ferreira

Matrícula 1046 · Engenharia Elétrica

E-mail

ana.ferreira@universidade.edu.br

CPF

014.882.***-**

Telefone

(55) 98xxx-2277

Endereço

Rua das Acácias, 210

Tipo de usuário

Aluno

DESEMPENHO ACADÊMICO

Disciplina	Nota	Faltas
Circuitos Elétricos I	8,5	2
Cálculo III	6,0	6
Física Experimental	9,2	0

Baixar histórico

Emitir declaração

← → ↺

http://unisystem.edu.br/perfil?id=1046

AL

Ana Luiza Ferreira

Matrícula 1046 · Engenharia Elétrica

E-mail

ana.ferreira@universidade.edu.br

CPF

014.882.***-**

Telefone

(55) 98xxx-2277

Endereço

Rua das Acácias, 210

Tipo de usuário

Aluno

DESEMPENHO ACADÊMICO

Disciplina	Nota	Faltas
Circuitos Elétricos I	8,5	2
Cálculo III	6,0	6
Física Experimental	9,2	0

► Quem está logado é o João, mas a tela mostra CPF, endereço e notas da Ana. Trocando o número no endereço dá para ver qualquer aluno — o sistema tinha que checar se o dado é seu.

http://unisystem.edu.br/recuperar

UniSystem

ETAPA 1

Verificação de identidade

Conta localizada: joao@universidade.edu.br

Qual é o nome do seu animal de estimação?

Thor

Continuar

Não recebe e-mails? Utilize a pergunta de segurança cadastrada na matrícula.

http://unisystem.edu.br/recuperar/nova-senha

UniSystem

ETAPA 2

Definir nova senha

Nova senha

2024

Confirmar nova senha

2024

Senha alterada. As sessões abertas continuam válidas.

Salvar nova senha

http://unisystem.edu.br/recuperar

UniSystem

ETAPA 1

Verificação de identidade

Conta localizada: joao@universidade.edu.br

Qual é o nome do seu animal de estimação?

Thor

Continuar

▶ O nome do cachorro está nas redes sociais. Com essa resposta qualquer um troca a senha da conta.

Não recebe e-mails? Utilize a pergunta de segurança cadastrada na matrícula.

http://unisystem.edu.br/recuperar/nova-senha

UniSystem

ETAPA 2

Definir nova senha

Nova senha

2024

Confirmar nova senha

2024

Senha alterada. As sessões abertas continuam válidas.

▶ Aceitou “2024” como nova senha e avisa que quem já estava conectado continua dentro: trocar a senha não expulsa o invasor.

Salvar nova senha

← → ↺

http://unisystem.edu.br/admin

UniSystem · Administração

InícioDisciplinasNotasJoão · Aluno

ADMINISTRAÇÃO

Gerenciar usuários

Gerenciar cursos

Gerenciar permissões

Relatórios

Configurações

Gerenciar usuários

Exportar CSV

Novo usuário

ID	Nome	E-mail	Perfil	Ações
1002	Coord. Registro	admin@unisystem.edu.br	Administrador	Editar
1045	João Pereira	joao@universidade.edu.br	Administrador	Editar
1046	Ana Luiza F.	ana.ferreira@universidade.edu.br	Aluno	Editar
1051	Prof. Nogueira	nogueira@universidade.edu.br	Professor	Editar

Área restrita à equipe de registro acadêmico. O menu principal não exibe estes itens para perfis de aluno.

ADMINISTRAÇÃO

Gerenciar usuários

Gerenciar cursos

Gerenciar
permissões

Relatórios

Configurações

Gerenciar usuários

Exportar CSV

Novo usuário

ID	Nome	E-mail	Perfil	Ações
1002	Coord. Registro	admin@unisystem.edu.br	Administrador	Editar
1045	João Pereira	joao@universidade.edu.br	Administrador	Editar
1046	Ana Luiza F.	ana.ferreira@universidade.edu.br	Aluno	Editar
1051	Prof. Nogueira	nogueira@universidade.edu.br	Professor	Editar

Área restrita à equipe de registro acadêmico. O menu principal não exibe estes itens para perfis de aluno.

► Esconder o botão não tranca a porta: digitando o endereço, o aluno entrou na administração. A checagem tem que ser feita no servidor.

← → ↻

http://unisystem.edu.br/login

10/09 • 08:12

Você saiu do UniSystem. Até logo, João.

Sessão encerrada às 08:11. Voltar para a tela de acesso.

Armazenamento • Cookies

nome

session

valor

8f2c4b91ae

expira

09/09/2027

httpOnly

false

secure

false

sameSite

none

Histórico do navegador • Estação BIB-07

2 usuários hoje

09/09 • 09:42 — UniSystem — Acesso

João

09/09 • 17:55 — navegador fechado

—

10/09 • 08:04 — UniSystem — Início (sessão de João ainda ativa)

visitante

Chat da equipe • #unisystem-dev

RB

Rafael • 17:20

“Os alunos não conseguem acessar funções administrativas porque os botões administrativos ficam ocultos para eles.”

CM

Camila • 17:24

“A validação do formulário de perfil está toda no JavaScript da página, então está resolvido.”

http://unisystem.edu.br/login

10/09 • 08:12

Você saiu do UniSystem. Até logo, João.

Sessão encerrada às 08:11. Voltar para a tela de acesso.

▶ O “Sair” só mudou de tela: com o botão Voltar os dados reaparecem. A sessão precisa ser encerrada de verdade no servidor.

Armazenamento • Cookies

nome session

valor 8f2c4b91ae

expira09/09/2027

httpOnlyfalse

securefalse

sameSite none

▶ O “crachá” da sessão está sem nenhuma trava: pode ser lido por outros sites e copiado na rede — sem precisar da senha.

Histórico do navegador • Estação BIB-07

2 usuários hoje

09/09 • 09:42 — UniSystem — Acesso

João

09/09 • 17:55 — navegador fechado

—

10/09 • 08:04 — UniSystem — Início (sessão de João ainda ativa)

visitante

Chat da equipe • #unisystem-dev

RB

Rafael • 17:20

“Os alunos não conseguem acessar funções administrativas porque os botões administrativos ficam ocultos para eles.”

CM

Camila • 17:24

“A validação do formulário de perfil está toda no JavaScript da página , então está resolvido.”

as duas frases mostram o mesmo erro: confiar no navegador em vez de checar no servidor

As 13 falhas do UniSystem

AUTENTICAÇÃO

Política de senha inexistente

Credenciais sem TLS

Fator único, sem MFA

Enumeração de contas

Tentativas ilimitadas

Senhas em texto puro

Recuperação por pergunta secreta

Telas 1, 2, 3 e 6

AUTORIZAÇÃO

Escalada de privilégio pelo formulário de perfil

Referência direta insegura (?id=)

Rota administrativa sem verificação no servidor

Três falhas que compartilham a mesma causa: a decisão de acesso ficou no cliente, não no servidor.

Telas 4, 5 e 7

SESSÃO

Sessão sem prazo de validade

Logout apenas visual

Cookie sem HttpOnly, Secure e SameSite

Nenhuma delas exige a senha do usuário para ser explorada — bastam o cookie e o computador compartilhado.

Telas 1, 3 e 8

Perguntas?

Autenticação responde quem é você.

Autorização responde o que você pode fazer.

Auditoria conta o que aconteceu.

